



# **Red Team : 20 missions plus tard**

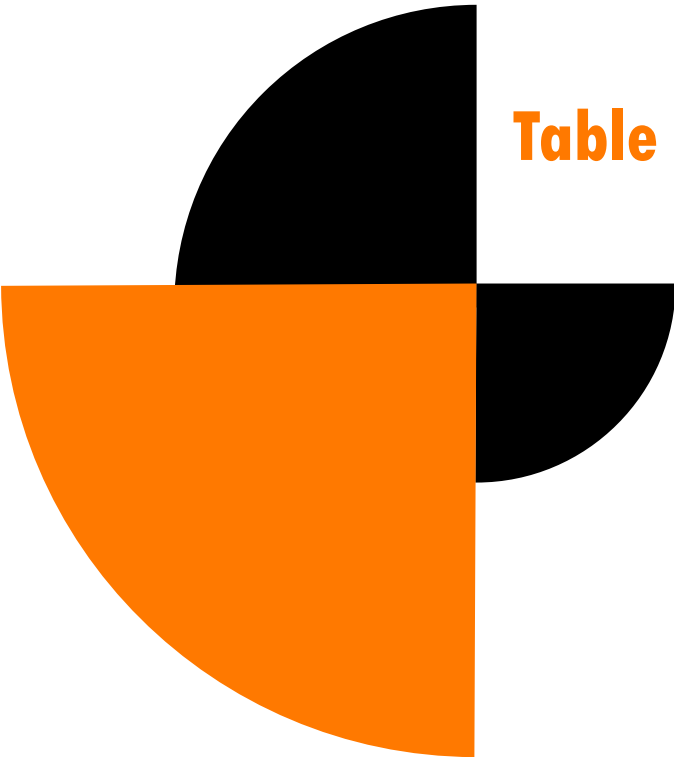
**Autopsie de quatre années de mutation  
offensive**



**STHACK 2026**



**Cyberdefense**



# Table des matières

- **Introduction**
- **Red Team description**
- **Quatre années de bascule côté client**
- **Ce qui marchait avant - et qui ne marche plus**
- **Ce qui fonctionne encore ou presque**
- **Nouveau jeu, nouvelles règles**
- **Epic fails**
- **Epic wins**
- **Conclusion**



# **Partie 1**

## **Introduction**

# whoami

Cyril Servieres (@M4yFly)

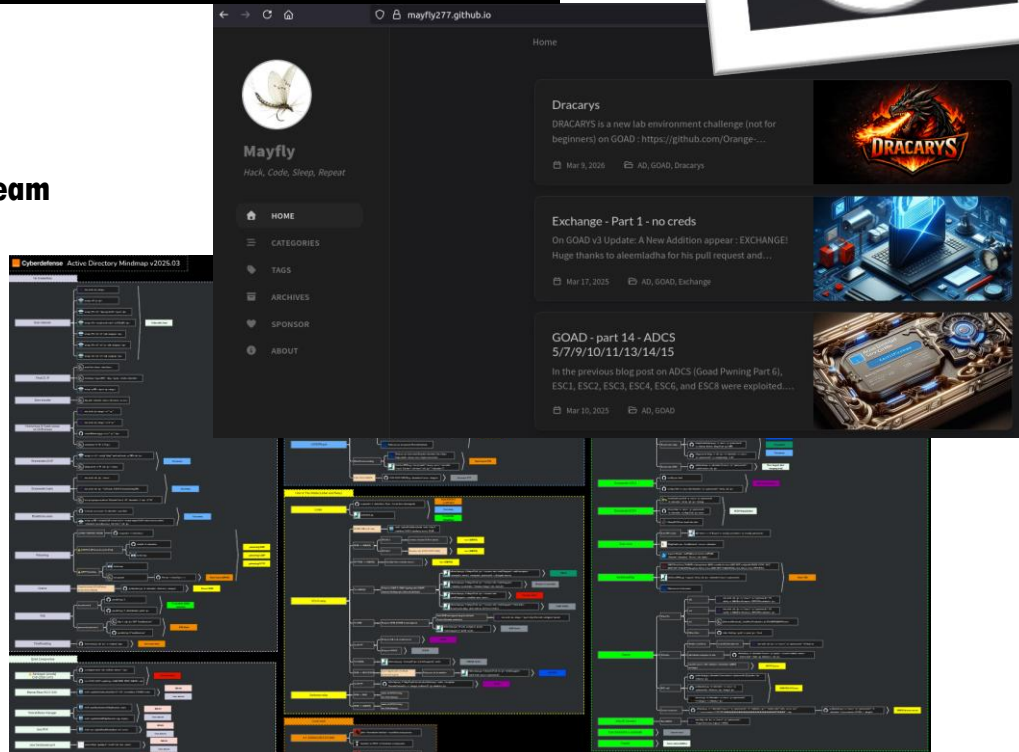
Red Team Leader at Orange Cyberdefense

- 10 ans Dev + DevOps
- 8 ans dans la sécurité Offensive dont 4 ans de RedTeam

OSCP/OSWE/OSED/OSEP/CARTP

Quelques Projets :

- Game Of Active Directory
- MindMap Active directory
- Arsenal
- Blog: <https://mayfly277.github.io/>



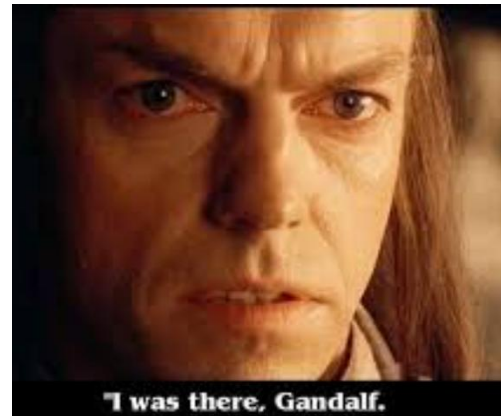
## Introduction

### Pourquoi ce talk ?

Quatre ans à n'avoir fait pratiquement que des missions Red Team

- Amélioration des défenses client
- Amélioration des détections
- Bascule cloud quasi systématique, principalement vers Entra ID
- Une évolution du tooling offensif
- Une évolution de l'infrastructure d'attaque
- Des utilisateurs qui représentent toujours autant le maillon le plus faible

Après une vingtaine de missions, voici un retour sur quatre années de mutation offensive...





## Red Team : missions et méthodes

### Tester la capacité réelle de détection et de réaction

Une équipe offensive spécialisée dans la simulation d'attaques avancées.

Elle utilise des techniques variées (social engineering, intrusion physique, exploitation technique)

Évaluer la sécurité globale et fournir des recommandations concrètes.

En résumé : Un test en conditions réelle de l'équipe de défense (Blue Team).



## Pentest ≠ Red Team ≠ Threat Actor

|                              | <b>PENTEST</b>      | <b>RED TEAM</b>                           | <b>Threat Actor</b> |
|------------------------------|---------------------|-------------------------------------------|---------------------|
| <b>Scope</b>                 | <b>Fixe</b>         | <b>Client + loi<br/>(C'est compliqué)</b> | <b>*</b>            |
| <b>Durée de mission</b>      | <b>1-3 semaines</b> | <b>1-6 mois</b>                           | <b>No limit</b>     |
| <b>Rédige un rapport</b>     | <b>OUI</b>          | <b>OUI</b>                                | <b>NON</b>          |
| <b>Peut ignorer la loi ?</b> | <b>NON</b>          | <b>NON</b>                                | <b>OUI</b>          |
| <b>Coût</b>                  | <b>\$</b>           | <b>\$\$</b>                               | <b>∞</b>            |

## Pentest ≠ Red Team ≠ Threat Actor

|                                                 | <b>PENTEST</b>                      | <b>RED TEAM</b>                                              | <b>Threat Actor</b> |
|-------------------------------------------------|-------------------------------------|--------------------------------------------------------------|---------------------|
| <b>Informations initiales ?</b>                 | <b>OUI</b>                          | <b>NON</b>                                                   | <b>NON</b>          |
| <b>Utilise de la persistance ?</b>              | <b>NON</b>                          | <b>OUI</b>                                                   | <b>OUI</b>          |
| <b>Peut faire du Social Engineering ?</b>       | <b>NON</b>                          | <b>OUI</b>                                                   | <b>OUI</b>          |
| <b>Accès physique ?</b>                         | <b>NON</b><br>(la plupart du temps) | <b>OUI (la plupart du temps)</b><br>(carte sortie de prison) | <b>OUI</b>          |
| <b>Est-ce que la Blue Team est au courant ?</b> | <b>OUI (le plus souvent)</b>        | <b>NON</b>                                                   | <b>NON</b>          |
| <b>Trouve toutes les vulnérabilités</b>         | <b>OUI</b><br>(Enfin essaye)        | <b>NON</b>                                                   | <b>NON</b>          |
| <b>Doit être discret ?</b>                      | <b>NON</b>                          | <b>ESSAYE</b>                                                | <b>ESSAYE</b>       |

## La notion de flag

### Mesurer un succès qui a du sens

Le flag représente **l'objectif significatif de la mission.**

#### Exemple de flags AD :

- Obtenir des privilèges importants sur le domaine Active Directory
- Prendre la main sur le système de sauvegarde

#### Exemple de flags Métier :

- Obtenir un accès au Core Banking System
- Récupérer des données stratégiques et financières (CODIR, Finances,...)
- Poser un implant physique dans les locaux
- Obtenir l'accès au code source de l'application X
- Obtenir un accès élevé sur le tenant o365
- Accéder à des données RH sensibles





## **Partie 3**

**Quatre années de bascule côté client**

## Évolution côté client

### L'heure de la maturité ?

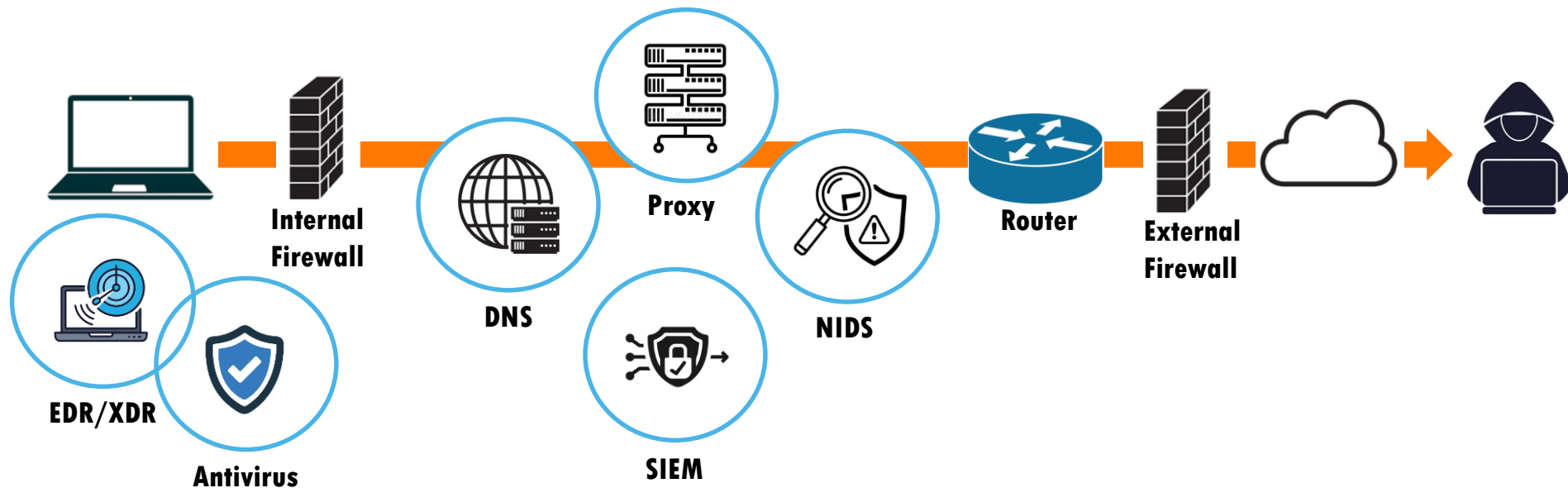
- **EDR/XDR everywhere**
- **Télémétrie++**
- **Détection++**
- **Hybridation du SI : Coexistence on-prem / cloud**
- **Identity First : Azure / Entra ID / SSO / Fédération / MFA**

### Conséquences

- **Complexification des chaînes de compromission**
- **Cloud == surfaces d'accès ++**

## Évolution côté client

### Défense on premise

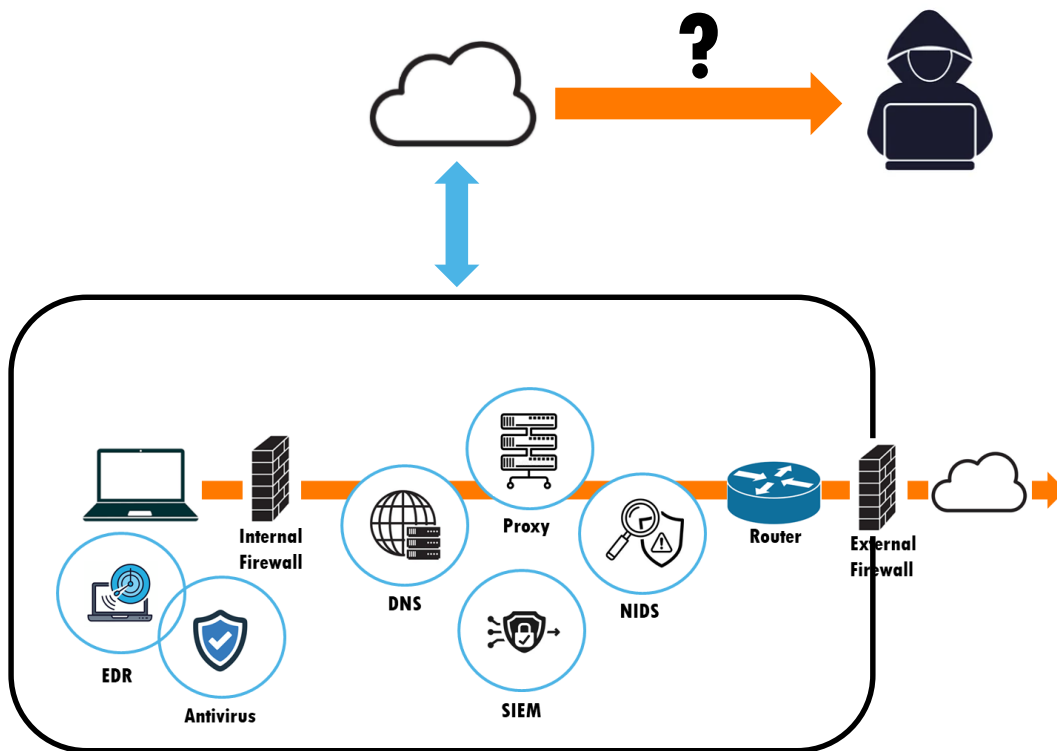


## Évolution côté client

**Le cloud : une autre surface d'attaque**

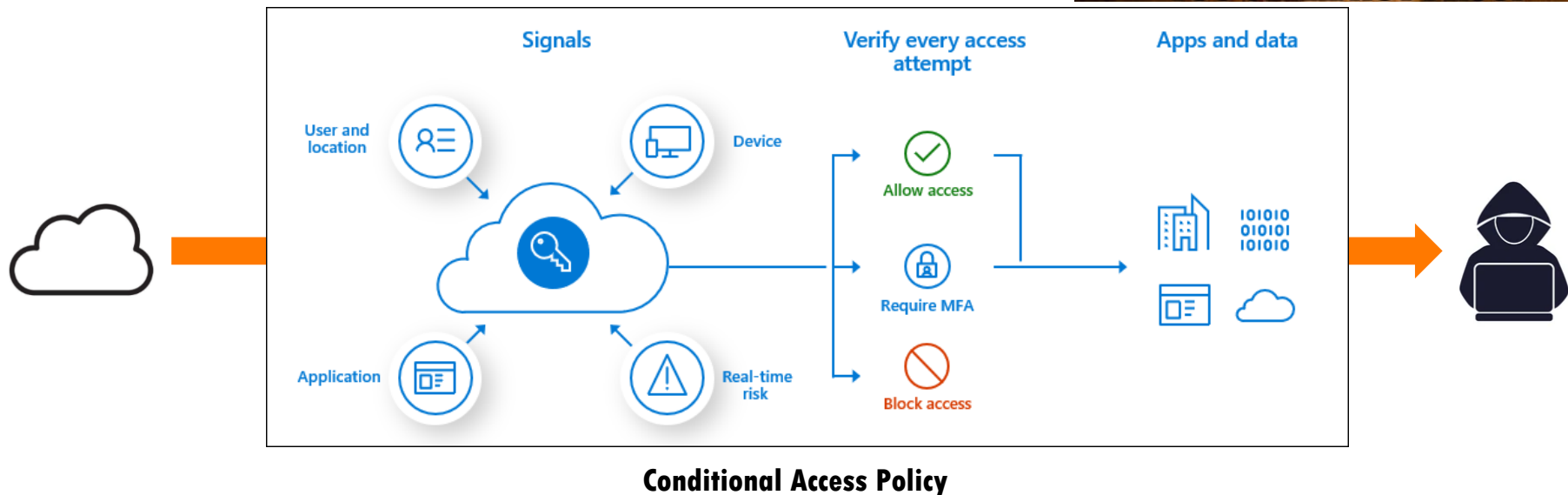
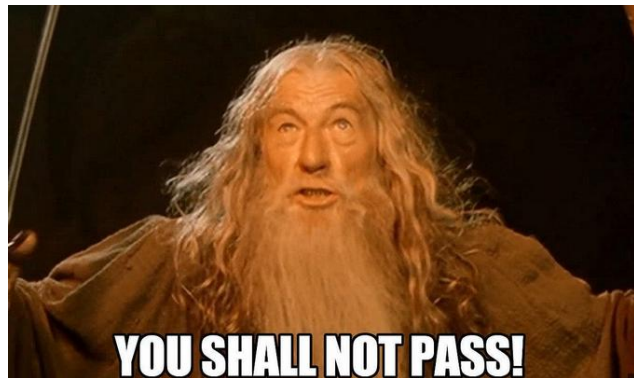
**Hybridation des SI**

**Datas on cloud => Flags on cloud**



# Évolution côté client

## Pas si simple non plus





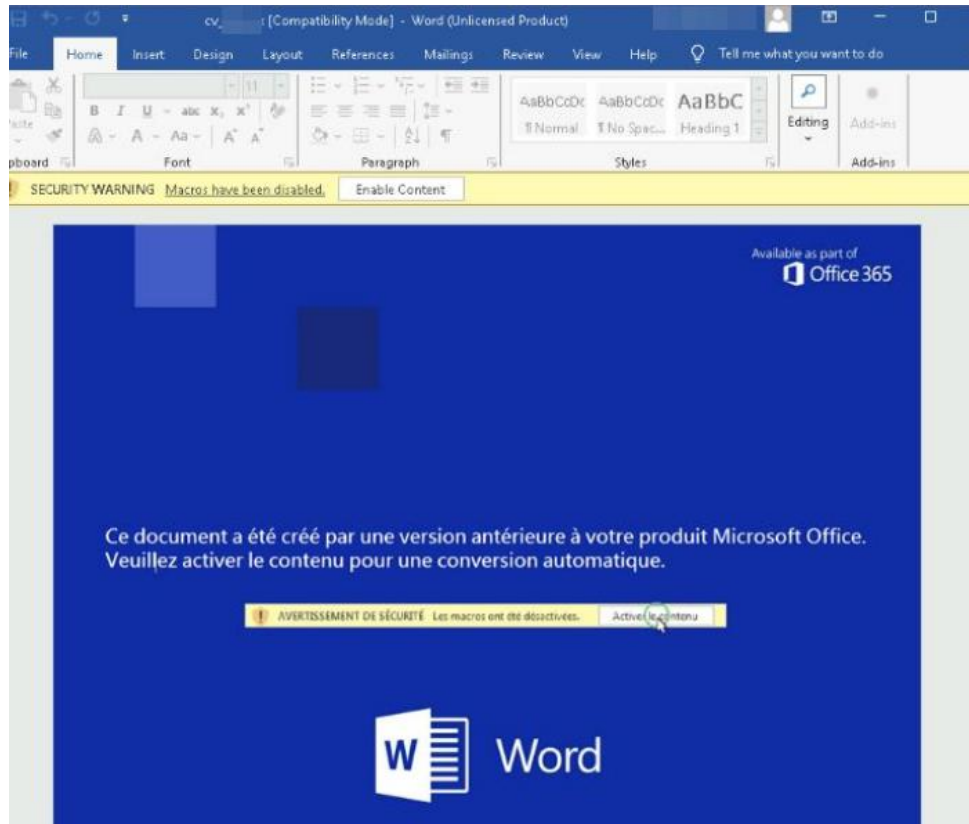
## **Partie 4**

**Ce qui marchait avant - et qui ne marche plus**

# Techniques obsolètes

## Les accès initiaux “simples”

- **A oublier**
  - **Macros**
  - **CPL**
  - **HTA**
  - **PS1**
  - **EXE**
  - **ISO**
  - **JS**
  - ...
- **A éviter sans signature**
  - **MSI**
  - **ClickOnce**
  - ...



Tout dépend de l'AV/EDR en face.

## Techniques obsolètes

### Ça a marché pendant très longtemps

- Exemple DLL SideLoading Teams
- Avantage : 1 seul fichier déposé = infection + persistance



**%localappdata%\  
Microsoft\Teams\  
version.dll**



**C:\windows\system32  
\version.dll**

**Malware**

**GetFileVersionInfoA**

...



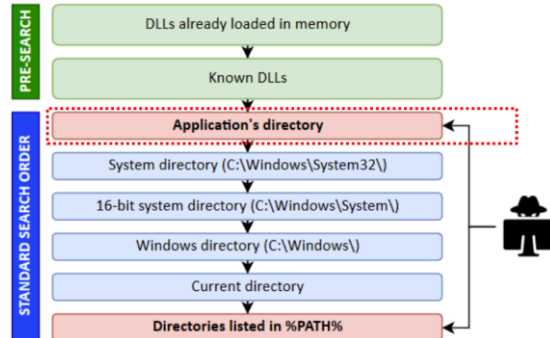
**C:\windows\system32\version.GetFileVersionInfoA**

Pointe vers la dll d'origine



Tué par :

- New Teams (fini localappdata)
- Détection des EDR sur les sideloads vers c:\Windows\system32



An executable file loaded an unexpected DLL file

Medium

DLL search order hijack

Medium

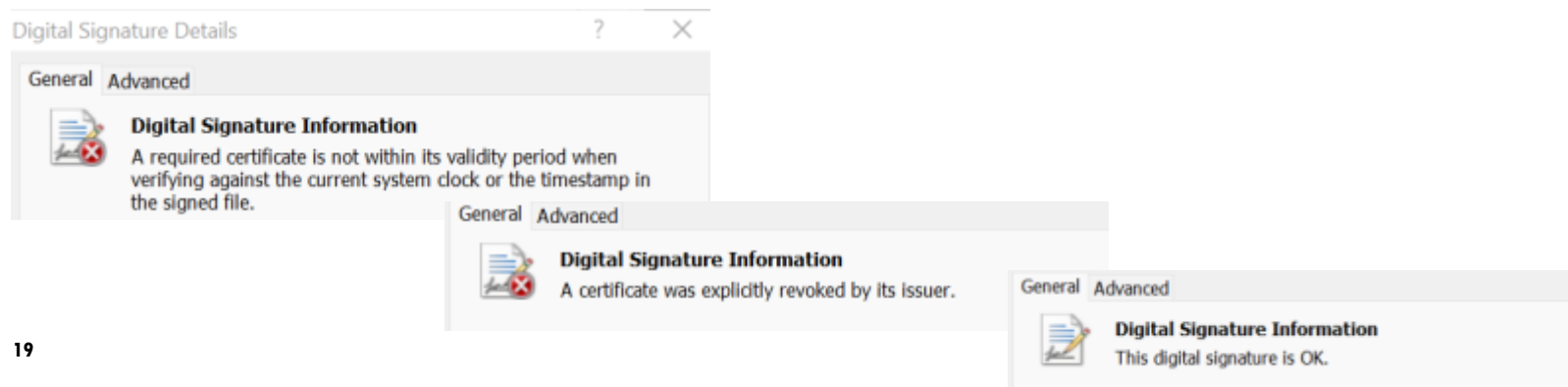
## Techniques obsolètes

### Signature de fichier

- **Avant :**
  - Copie des informations de signature au format brut
- **Maintenant :**
  - Soit auto-signé
  - Soit leak de certificat (expiré, révoqué, valide) => problème légal



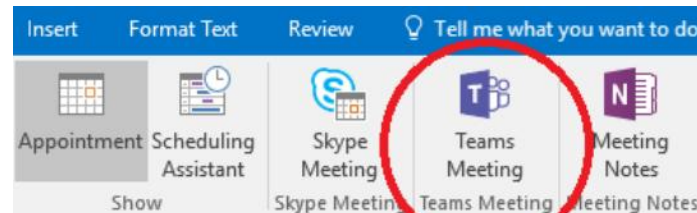
**Bonus : récupérer un certificat dans l'infrastructure du client et signer ses binaires avec le certificat du client** 🕶️



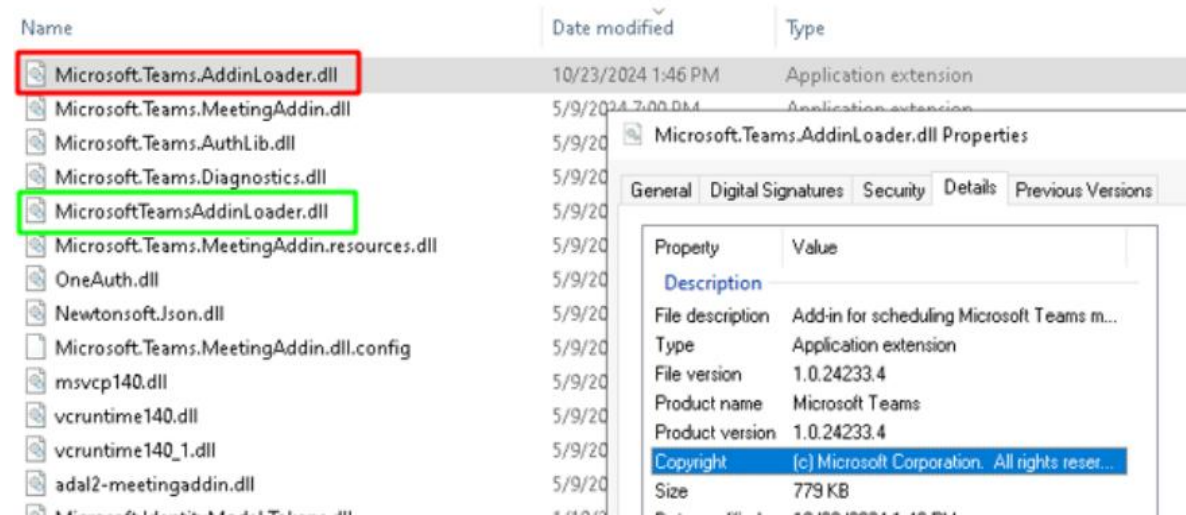
## Techniques obsolètes

### Ça peu encore sous certaines conditions

- DLL Proxying
- Plugin TeamsMeetingAddIn
- Avantage :
  - dll pas dans c:\windows\system32
- Problème :
  - Tué par new Outlook
- Fonctionne encore très bien sur d'autres binaires



(C:) > Users > alice > AppData > Local > Microsoft > TeamsMeetingAdd-in > 1.24.13005 > x64



## Techniques obsolètes

### Les techniques d'exécution trop exposées

- Problème du tooling public
  - Signatures
  - Heuristiques
  - IoC
  - Corrélations multi-couches côté défense
  - Chemins d'exécution
  - Pattern réseau
- Tooling AD : Certipy, NXC, Impacket, bloodhound-ce.py, soaphound, ... => Dead sans modifs

Suspicious Kerberos authentication (TGS-REQ)

■ ■ ■ Medium

Suspicious Kerberos authentication (AS-REQ)

■ ■ ■ Medium

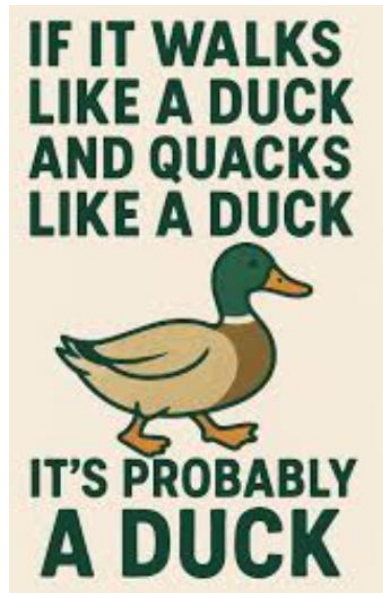
- De même, la plupart des Formations/Certifications taggués « red team » ne permettent pas (directement) de contourner les protections client actuelles.

Suspicious 'ETW' behavior was blocked

■ ■ ■ Low

Suspicious 'AMSI\_Patch' behavior was blocked

■ ■ ■ Low



## Utilisation de tool public

- Du coup plus de tools public ?
- Réponse : Si mais modifié !
  - Customisation, Obfuscation, réécriture d'une partie du code
  - Recherche et modifications des IOC
  - Désactivation/absences de détection (EDR, AV)
    - Pas de défense, pas de détection
  - Tests en lab !



**PUBLIC ==> A customiser pour une utilisation en  
RED TEAM**



## **Partie 5**

**Ce qui fonctionne encore ou presque**

## Ce qui fonctionne encore (ou presque)

Le maillon le plus faible de la chaine quelque soit le groupe audité reste toujours l'utilisateur.

- Le social engineering
- Phishing
- Implant physique
- Password spray
- Certains payloads
- ...

Mais cela devient de plus en plus compliqué d'atteindre la cible !



# Ce qui fonctionne encore (ou presque)

## Utiliser l'existant : Exemple Quick Assist

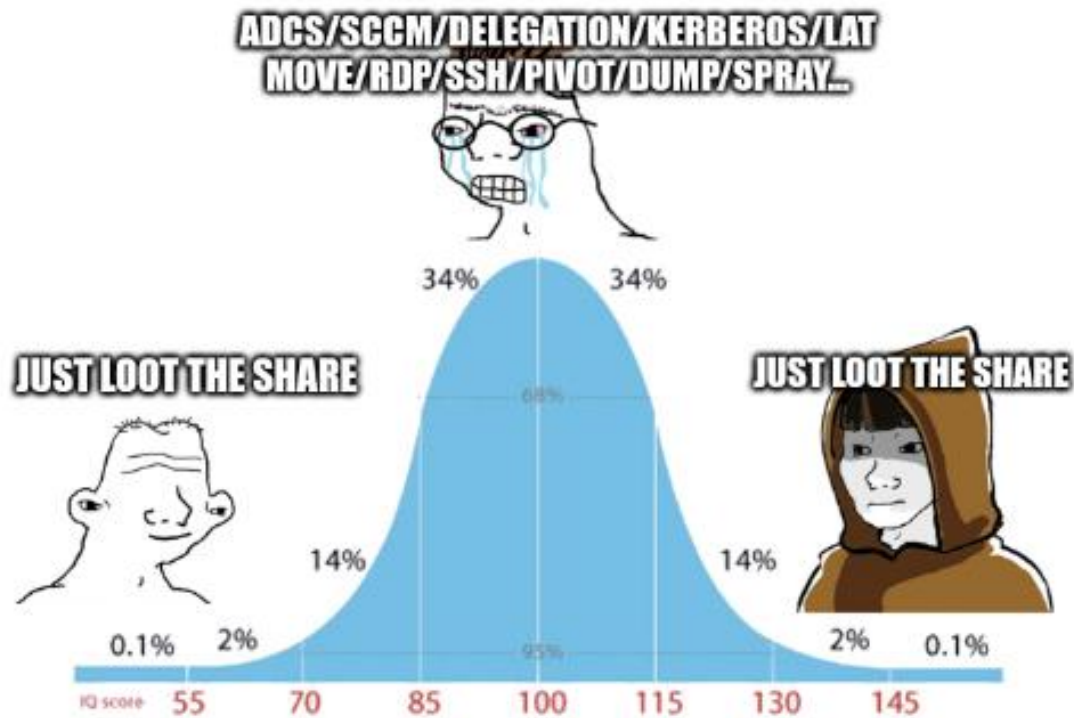
The image shows a Windows search interface with 'Quick Assist' as the best match. Below the search bar, there are sections for 'Apps', 'Search the web', 'Documents (6+)', and 'Settings (7+)'. The 'Quick Assist' app is listed with a blue icon. To the right, a larger preview of the app shows the 'Quick Assist' title and a 'Open' button. Below the search results, the Quick Assist application window is open, displaying the 'Get help' section. It prompts the user to 'Let someone you trust view your screen or take control of your PC.' and provides a 'Security code from assistant' field with a 'Submit' button. The 'Help someone' section is also visible, prompting the user to 'Ask someone you know to share their screen.' and providing a 'Help someone' button. On the right, the 'Share this security code' section shows the code '49EU14' and a 'Copy code' button. The code expires in 09:58. Below the code, there are links for 'Give instructions' and 'Sign in with a different account'.



\*\*\* initial beacon from [redacted] @192.168.1.71 ([redacted])

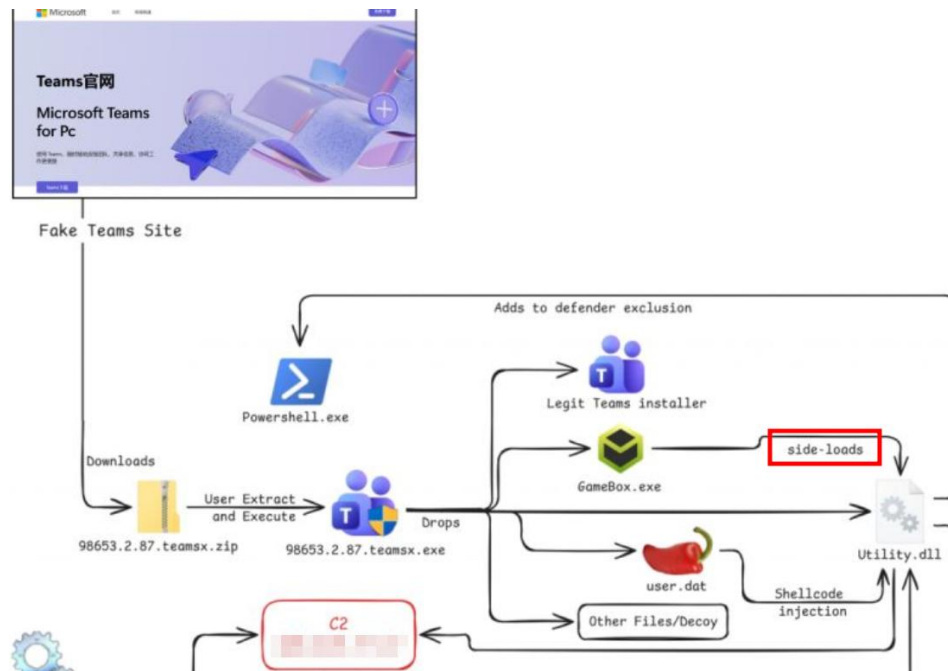
## Ce qui fonctionne encore (ou presque)

### Le LOOT !



## Ce qui fonctionne encore (ou presque)

- Le sideloading d'exécutable signé est encore très prisé



# Évolution côté offensif

## Complexité croissante

### Malware de plus en plus évolués

#### Contournement des anti-virus & EDR à différents niveaux :

- Dépôt du malware
- Exécution de la charge utile
- Persistance

=> Le malware s'exécute en plusieurs étapes étalées dans le temps pour éviter des corrélations d'événements.



Internal  
Firewall



EDR / XDR



Antivirus



SIEM

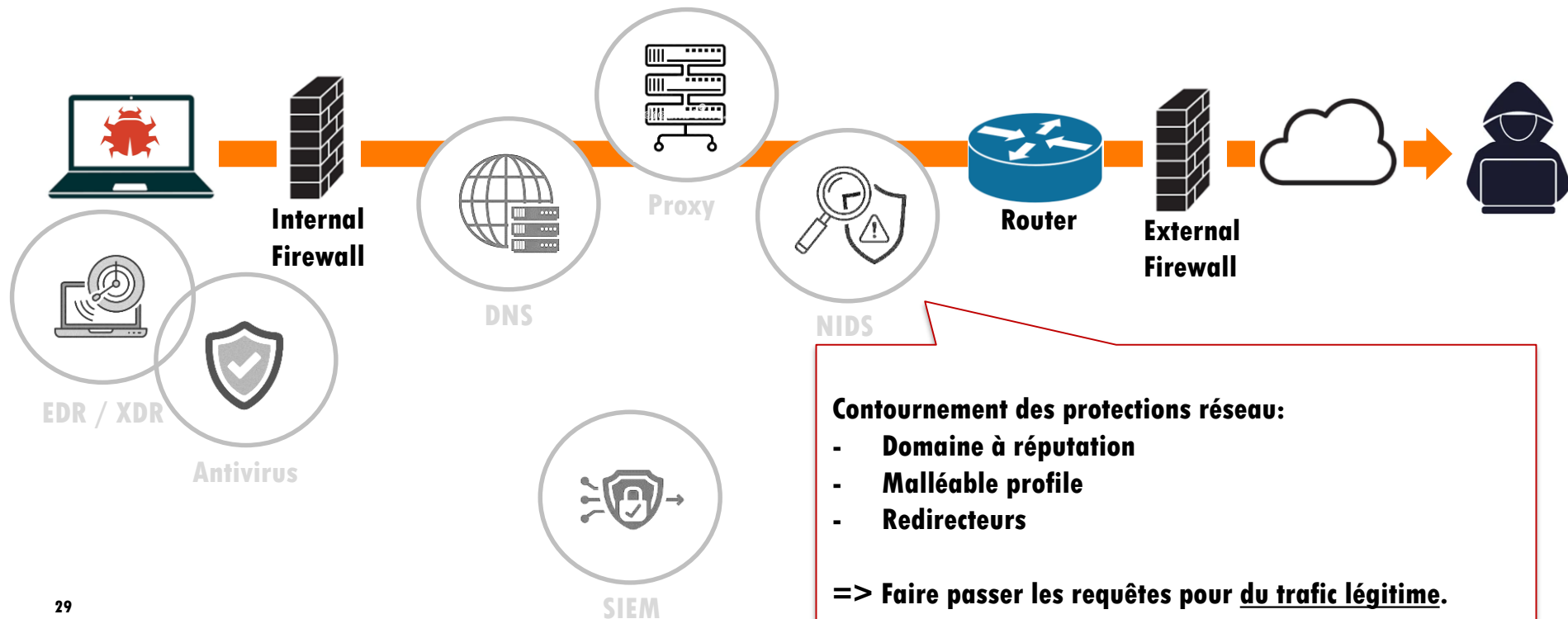


Internal  
wall



## Évolution côté offensif

### Complexité croissante





## **Partie 6**

**Nouveau jeu, nouvelles règles**

## Adaptation offensive

# La Red Team doit innover et s'industrialiser !

- Fini l'époque de la RT avec des outils de pentest
- Évolution de l'infrastructure Red Team & du tooling
  - Domaines
  - Redirecteurs
  - C2
  - Cloud
  - Lab
  - Automatisation de l'infrastructure et des payloads !

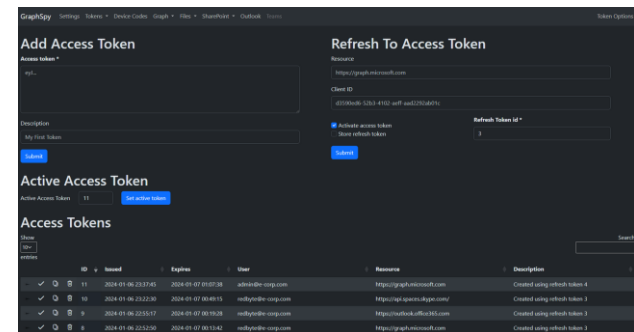
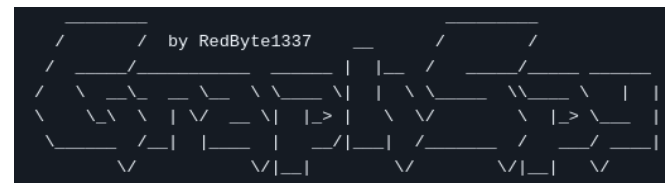
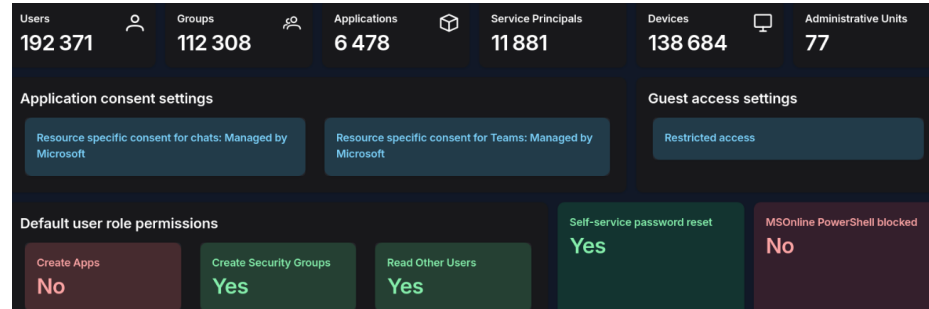
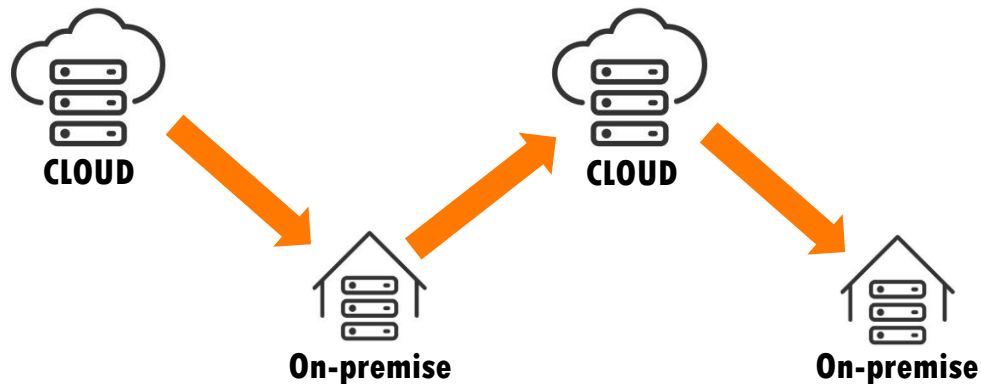
A screenshot of the REDSider web interface. The left sidebar contains a navigation menu with items: Home, Missions, Tasks status, C2 Profiles, VMs (highlighted), CDN, WebApp, DNS, Redirectors, Dropper, Hephaistos, Patch Obfuscate, Cobalt Profiler, and Smuggling. The main content area is titled 'Virtual Machines' and shows a table of VMs. Above the table are buttons for 'SYNCHRONIZE', '+ ADD', 'RUN ANSIBLE PLAYBOOK', 'OPEN SSH SHELL', and 'DELETE'. The table has columns for ID, Provider, Type, Instance ID, Name, Status, and Os. All VMs listed are running Ubuntu 24.04.

| ID  | Provider | Type | Instance ID | Name | Status  | Os           |
|-----|----------|------|-------------|------|---------|--------------|
| 181 |          |      |             |      | running | Ubuntu 24.04 |
| 183 |          |      |             |      | running | Ubuntu 24.04 |
| 184 |          |      |             |      | running | Ubuntu 24.04 |
| 191 |          |      |             |      | running | Ubuntu 24.04 |
| 193 |          |      |             |      | running | Ubuntu 24.04 |
| 195 |          |      |             |      | running | Ubuntu 24.04 |
| 215 |          |      |             |      | running | Ubuntu 24.04 |
| 216 |          |      |             |      | running | Ubuntu 24.04 |

# Adaptation offensive

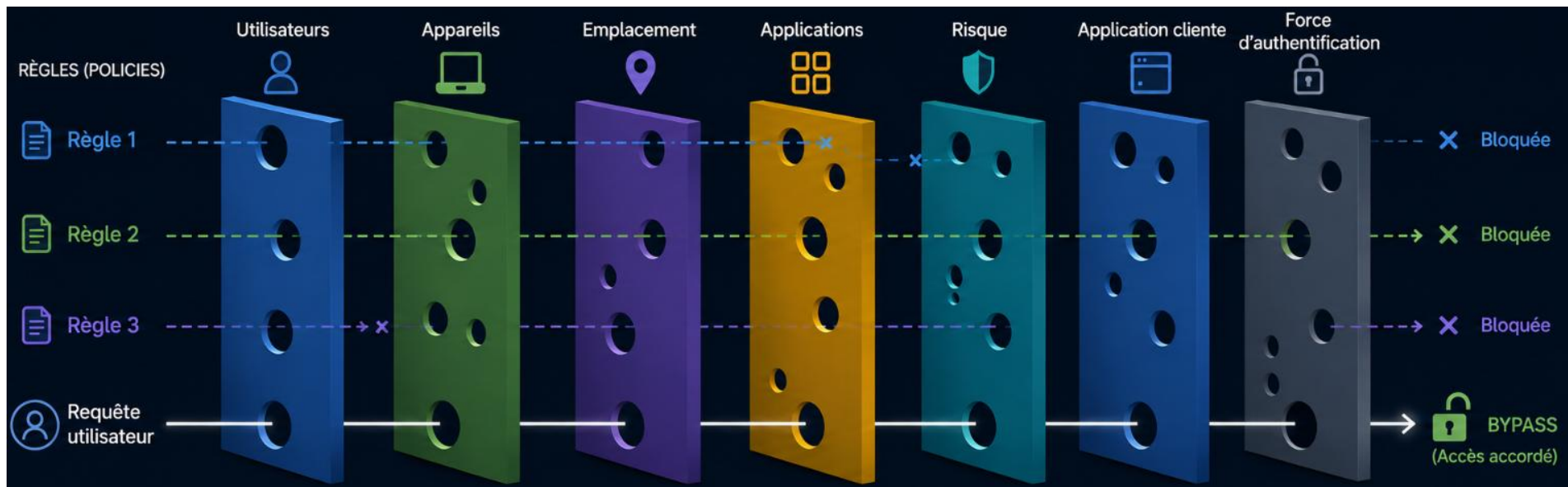
## Cloud entrée ou pivot

- DATA in cloud => RED TEAM in cloud



## Adaptation offensive

### Conditional Access Policy



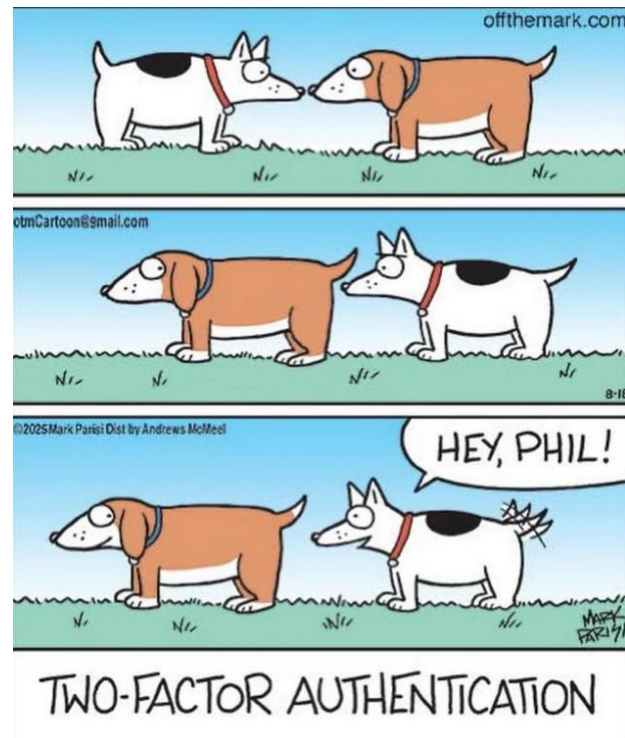
#### Résultat CAP:

- Accès autorisé
- Accès refusé
- MFA
- Device domain Join
- Device compliant
- SignIn Frequency
- ...

# Adaptation offensive

## CAP

Microsoft Authenticator



|               |                                                                                                                                                                   |
|---------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Applies to    | <b>Including:</b> All users<br><b>Excluding:</b> Users: [redacted]<br>Users in groups: [redacted]                                                                 |
| Resources     | <b>Including:</b> All resources<br><b>Excluding:</b> Resources: Microsoft Intune, Citrix Cloud, Global-365, Workplace from Meta, ServiceNow Production, Microsoft |
| On platforms  | <b>Including:</b> All platforms<br><b>Excluding:</b> Android, iOS, Windows_Phone                                                                                  |
| Using clients | <b>Including:</b> Mobile and Desktop clients, Browser                                                                                                             |
| At locations  | <b>Including:</b> All locations<br><b>Excluding:</b> All trusted locations                                                                                        |
| Controls      | <b>Requirements (any):</b> Mfa                                                                                                                                    |

```

[WARN] 25! - AADSTS50126: Invalid email or password. Account could exist.
[WARN] 5! - AADSTS50126: Invalid email or password. Account could exist.
[WARN] 2025! - AADSTS50126: Invalid email or password. Account could exist.
[SUCC] ! - AADSTS50076: The response indicates MFA (Microsoft) is in use.
[WARN] - AADSTS50126: Invalid email or password. Account could exist.
[WARN] 25! - AADSTS50126: Invalid email or password. Account could exist.

```

## Adaptation offensive

### Un tool pour faire l'analyse

- Problème Trop de règles == Trop de combinaisons
- <https://github.com/dirkjanm/ROADtools/pull/153>



```
→ plugins git:(capfilter) python3 capfilter.py -h
usage: capfilter.py [-h] [-d DATABASE] [-u UPN] [-m] [-c] [-r] [-p {Android,iOS,macOS,Windows_Phone,Windows,Linux,ChromeOS,Unknown}] [-l LOCATION]
                    [--resource_id RESOURCE_ID] [--ip IP] [--country ISO2]

ROADrecon CAP analysis plugin

options:
  -h, --help                show this help message and exit
  -d DATABASE, --database DATABASE
                            Database file or SQLAlchemy URL
  -u UPN, --upn UPN          User principal name filter
  -m, --match                Show matching rules only
  -c, --control              Show control rules only
  -r, --reporting            Show reporting as a matching rule
  -p {Android,iOS,macOS,Windows_Phone,Windows,Linux,ChromeOS,Unknown}, --platform {Android,iOS,macOS,Windows_Phone,Windows,Linux,ChromeOS,Unknown}
                            Filter on a platform
  -l LOCATION, --location LOCATION
                            Filter on a location (by display name)
  -t, --trusted_location     Mark the location as trusted
  --client {Browser,Legacy Clients,Exchange ActiveSync,Mobile and Desktop clients}
                            Filter on client type
  --resource RESOURCE       Filter on resource display name
  --resource_id RESOURCE_ID
                            Filter on resource app ID
  --ip IP                    Filter on a source IP address (matched against CIDR ranges)
  --country ISO2             ISO 3166-1 alpha-2 country code (e.g. NG, RU, FR) – can be used alone or combined with --ip
```

## Adaptation offensive

- **Exemple mission : Windows Phone + API call => MFA bypass !**



```
redrecon git:(main) X python3 redrecon.py -d /roadrecon.db -u -m -c -p Windows_Phone --resource_id 1fec8e78-bce4-4aaf-ab1b-5451cc387264 -l france
Filter by resource :Microsoft Teams
```

### Conditional Access Policies

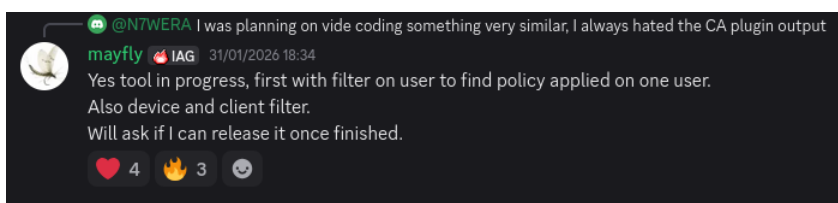
[illegible]

Filter by resource :Microsoft Teams

**FREEDOM ! ! ! ! !**

# Adaptation offensive CAP

- ~2 semaines après la création du tool pour la mission, Specter Ops à sorti un tool avec la même idée en public :)
- <https://specterops.io/blog/2026/02/17/stop-the-cap-making-entra-id-conditional-access-make-sense-offline/>
- <https://github.com/rbnroot/CAPSlock>



**CAPSlock**  
CA POLICY ANALYSTS

Get Policies  
What If Analysis  
**Analyze Gaps**  
All Policies  
Locations

### Analyze Gaps

Systematically search for CA enforcement gaps by permuting sign-in scenarios

**Note:** This analysis generates multiple scenarios. Any parameters left unspecified will be automatically permuted.

#### Analysis Configuration

User Principal Name (required)  
lowleveluser@darrusrobinson.com

Resource / App ID  
0259f81-2d62-4ff1-becf-6204eb85e52

Max Scenarios  
1000

Fixed Trusted Location (optional)  
Permute all

Fixed Sign-in Risk (optional)  
Permute all

Fixed Auth Flow (optional)  
Permute all

Fixed Device Compliant (optional)  
Permute all

ACK / User Action  
um:user:registerdevice

Fixed Platform (optional)  
macOS

Fixed Client App (optional)  
Permute all

Fixed User Risk (optional)  
Permute all

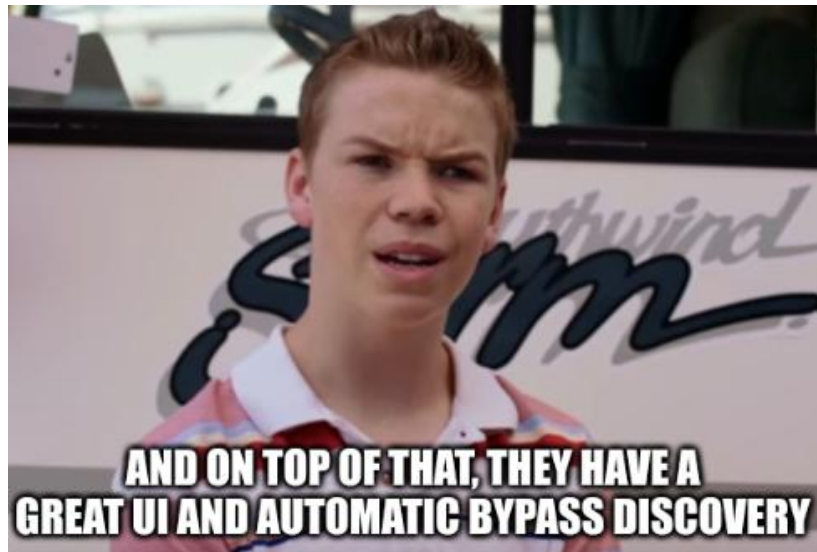
Fixed Device Filter (optional)  
Permute all

Fixed Device Entra/Hybrid Joined (optional)  
Permute all

**Start Analysis**

#### Analysis Results

|                          |                           |                         |                               |
|--------------------------|---------------------------|-------------------------|-------------------------------|
| <b>1000</b><br>SCENARIOS | <b>288</b><br>NO POLICIES | <b>0</b><br>REPORT-ONLY | <b>288</b><br>LOCATION BYPASS |
|--------------------------|---------------------------|-------------------------|-------------------------------|



## **Adaptation offensive**

### **Nouvelles approches**

**Une fois l'accès conditionnel passé, c'est très souvent une énorme source pour la RED TEAM**

- **Sharepoint**
  - **OneDrive**
  - **E-Mail**
  - **Teams**
  - **Accès à la graph API**
- 
- **Objectifs de mission**
  - **Accès On-Premise (sharepoint, onedrive,...)**
  - **Internal Phishing (Teams, Outlook,...)**



## **Partie 7**

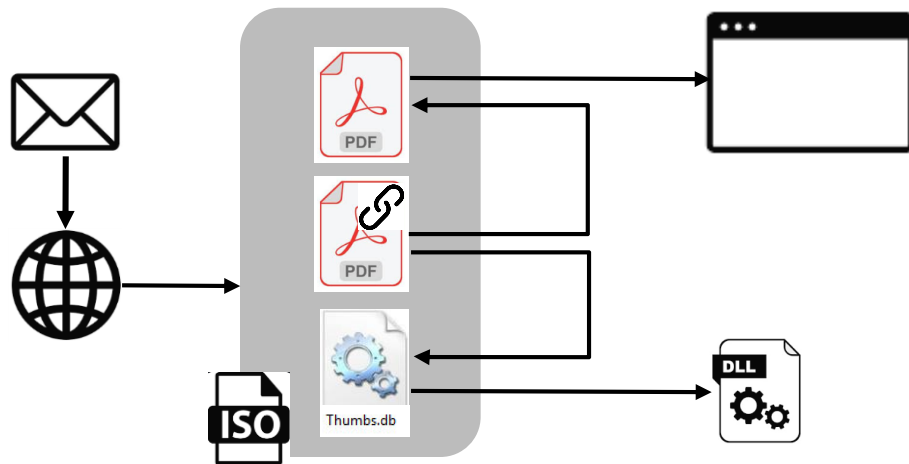
### **Epic fails**

**Chaque échec est une source d'apprentissage**

## Epic fail RED

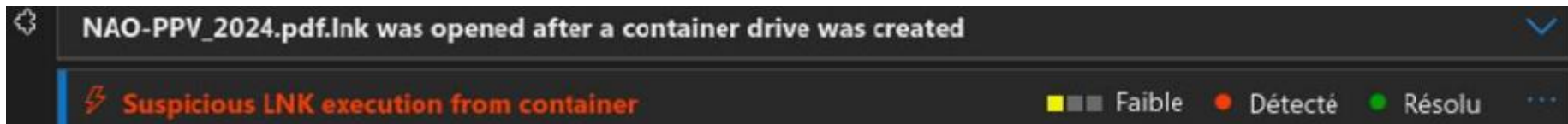
### Test insuffisant en lab

Spear phishing : Drop de dll via un fichier Iso contenant PDF + Ink



OK en lab, KO Coté client

En ajoutant la composante « ouverture depuis Outlook », l'EDR a considéré qu'il y avait suffisamment de signaux faibles pour une alerte.

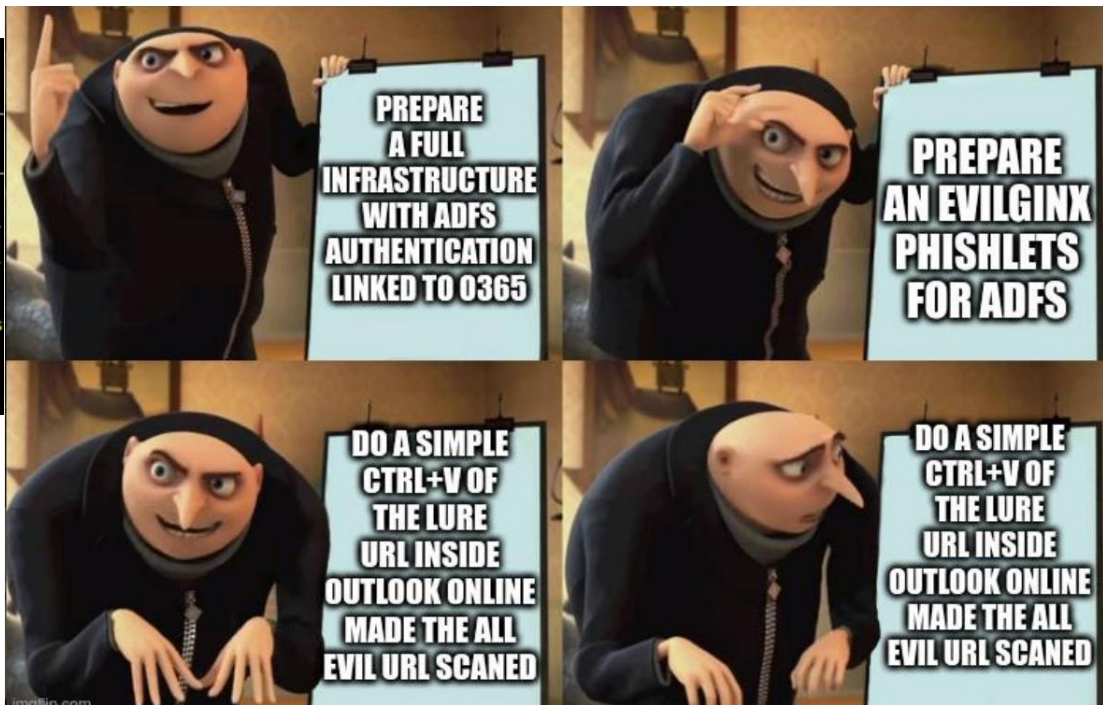
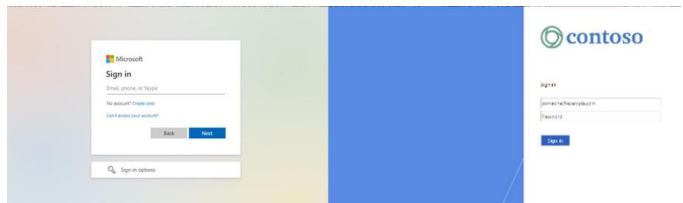


## Epic fail RED

### Le copy paste malencontreux



```
15:23:47] [inf] Evilginx Mastery Course: https://academy.breakdev.org/evilginx-mas
15:23:47] [inf] loading phishlets from: /home/ubuntu/evilginx/phishlets
15:23:47] [inf] loading configuration from: /root/.evilginx
15:23:47] [inf] blacklist: loaded 42 ip addresses and 0 ip masks
15:23:47] [war] phishlets: hostname 'login.microsoftonline.com' collision between
```

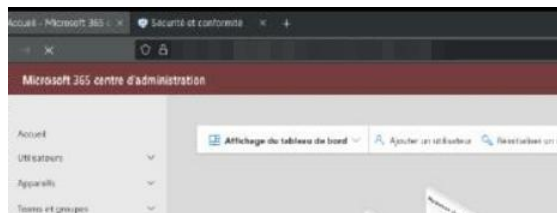


## Epic fail RED

### Utilisation du compte « brise glace »

Détection via une règle custom chez eux, mais surtout :

Panique à bord chez le client !



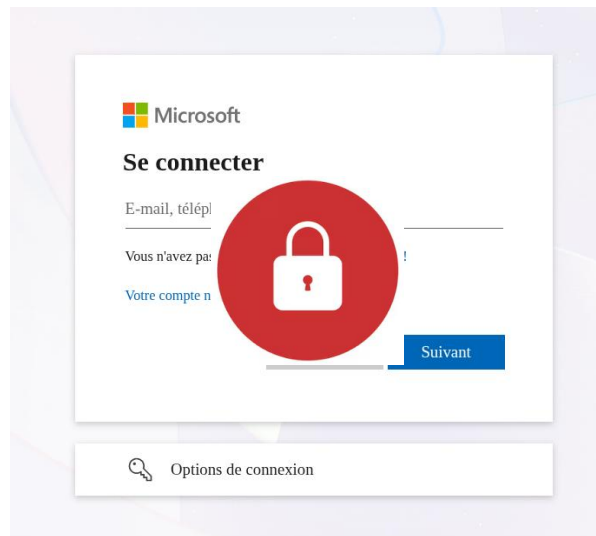
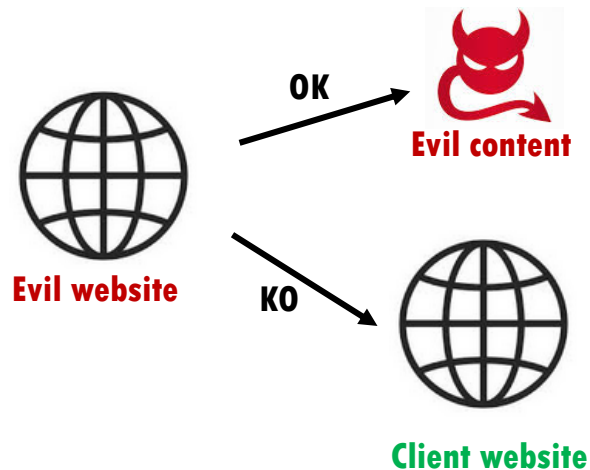
be stealth  
and try to  
extract  
cookie or tokens



use the  
"brise glace  
Account"  
cause there  
is no MFA on it

## Epic fail RED

### Blocage d'url redirigée vers le client



**La blue team a détecté qu'un site redirigeait vers chez eux et a bloqué le site**

## Epic fail RED

### Mauvaise énumération de la machine

On rebondit sur une machine linux avec un GLPI.

Mauvaise énumération de la machine, on rate la présence de MDE dessus.

Résultat : Microsoft fait un blog post sur l'attaque effectuée !

[Research](#) • May 8 • 5 min read

## Active attack: Dirty Frag Linux vulnerability expands post-compromise risk

By [Microsoft Defender Security Research Team](#)

[Listen to this post](#)



0:00 / 0:00

1X



Powered by Microsoft Copilot

## Exploitation scenarios

**Threat actors** may leverage Dirty Frag after obtaining local code execution through several common intrusion paths, including:



## Epic fail RED & BLUE

NTDS dans les shares => détection => OK no problem

- Listing des fichiers dans les shares communs:
- \\serveur\files\sources\Active directory\ntds.dit dans les fichiers lisible par tous !
- Après une longue hésitation, téléchargement du fichier.
- La sonde réseau capte la signature d'un fichier NTDS dans les flux interne et lève une alerte.

=> L'alerte est vu et traitée par l'analyste comme ... faux positif !



## **Epic fail BLUE**

**Soc qui reçoit une alerte sur un des redirecteurs mais le marque en faux positif car il pointe vers un site teams-presence**

- **Infection OK**
- **Rien ne sonne**
- **Quelques temps plus tard, une alerte est levée, une machine fait des appels réguliers vers un hostname en teams-presence.xxx**

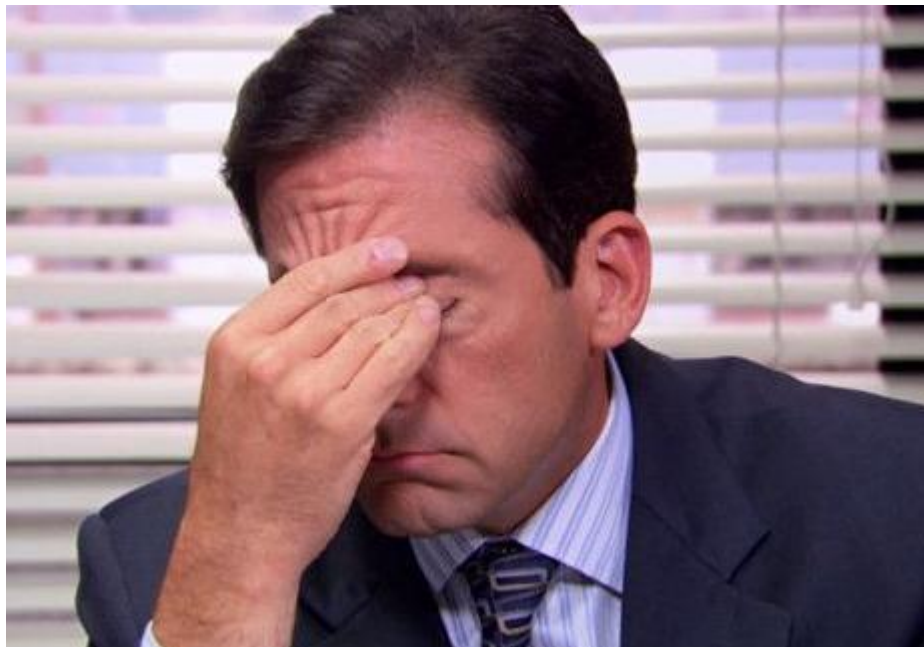
**=> Clos par l'analyste car « teams-presence » paraît légitime.**



## Epic fail BLUE

**Mais encore:**

- **Décomissionnement du mauvais poste**
- **Remise en service d'un poste infecté après un nettoyage insuffisant**
- **Mails d'alerte si passage en root sur un serveur qui n'a jamais été lu**
- ...

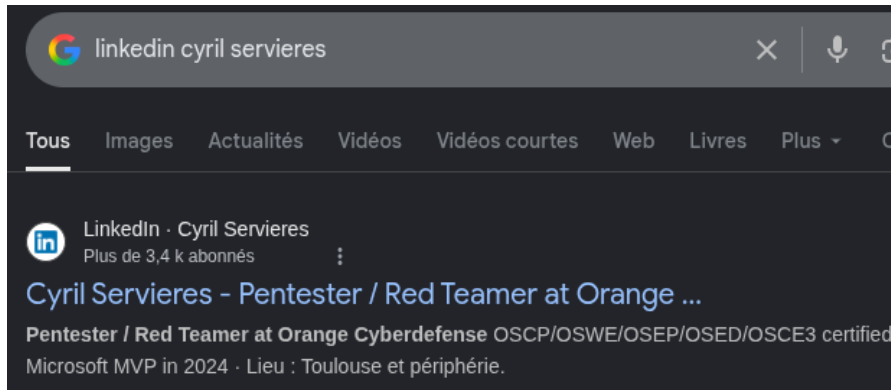


## Epic fail WHITE

### Compte d'Assumed Breach : cyril servieres (cservieres)

#### Problème :

- Victime pas présente plus de 5h par jour.
- Compte d'assumed breach demandé.
- Surprise, le compte s'appelle : cservieres !

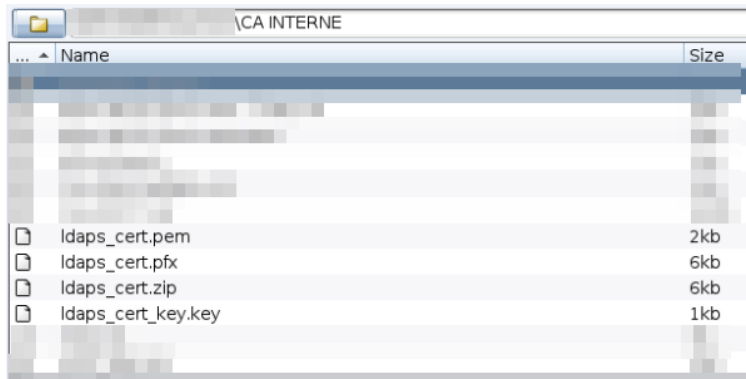


```
15:08:19 *** initial beacon from cservieres@10. [REDACTED]
```



## Epic win RED

Récupération du certificat ldap directement dans les partages de fichiers => DA



Utilisation du certificat ldap

=> ldap shell en tant que compte T0



## Epic win RED

### Exploitation du site www du client pour y monter notre propre page de helpdesk

- Site www du client
- Découverte d'une vulnérabilité local file disclosure
- Extraction de l'ensemble du code source Ruby On Rails de l'application web
- Découverte d'un moyen de forger des cookies
- Accès admin
- Création d'une fausse page `www.site-client.com/helpdesk`



# Epic win RED

## Récupération de rapport d'audit d'un pentest précédant

- Durant la mission on récupère des privilèges « IT », utilisateur support niveau 1
- L'utilisateur a accès à un partage IT interne
- Récupération des rapports d'audit externe et INTERNE du client.
- Le prestataire avait également donné toutes les traces NXC avec la liste des partages et des droits
- Un des rapports contenait même un compte utilisateur encore valide sur l'externe !

### CONFIDENTIEL

Ce document contient des informations confidentielles protégées par le secret professionnel.  
Son contenu est strictement réservé aux personnes accréditées dans la liste de diffusion de ce document.

|      |     |  |                       |             |
|------|-----|--|-----------------------|-------------|
| .201 | 445 |  | [*] Enumerated shares |             |
| .201 | 445 |  | Share                 | Permissions |
| .201 | 445 |  | ----                  | -----       |
| .201 | 445 |  |                       |             |
| .201 | 445 |  | Intranet\$            | READ,WRITE  |
| .201 | 445 |  | Intranet_Dev\$        | READ,WRITE  |
| .201 | 445 |  | IPC\$                 | READ        |
| .201 | 445 |  |                       |             |



## Epic win RED

### Close d'un ticket helpdesk indiquant le password spray en notant le helpdesk 5/5 et en backdorant le compte Azure

- Un password spray azure nous donne un compte avec MFA non enrôlé.
- On enrolle authenticator sur le compte.
- On ajoute une persistance sur le compte.
- On se connecte au service de ticketing pour clore l'incident « User Alert for Password Spray ».
- On répond au rating du helpdesk en mettant la note de 5/5.

INC [REDACTED] - High Risk User Alert for Password Spray  
on [REDACTED]

Your incident has been resolved.

The incident will automatically close in 7 days.

Service offering: Entra ID

Configuration item: Azure AD Authentication Connected Service

#### Summary details

Resolved by [REDACTED]

## Epic win BLUE

« On a vu une connexion ssh et du coup on a creusé »



- On est en interne, on vient de découvrir des accès root ESXI.
- On active le ssh sur un des ESXI, on snapshot un des DC et on effectue l'extraction de la NTDS du snapshot directement depuis la machine ESXI.
- On chiffre la NTDS extraite pour ne pas se faire voir par une sonde réseau et on exfiltre le tout.
- Tout a été vérifié, aucun EDR n'était présent sur l'hyperviseur et notre chemin jusqu'à celui-ci a été relativement discret.

```
7zs l aaaa-flat.vmdk # identifier le fichier 'Basic data'
7zs e aaaa-flat.vmdk '<basic data partition>.ntfs'
7zs e <basic data partition>.ntfs Windows/NTDS/ntds.dit
7zs e <basic data partition>.ntfs Windows/System32/config/SAM
7zs e <basic data partition>.ntfs Windows/System32/config/SECURITY
7zs e <basic data partition>.ntfs Windows/System32/config/SYSTEM
```

## Epic win BLUE

### « On a vu une connexion ssh et du coup on a creusé »

- Mais c'est sans compter sur l'œil d'un IT qui a « vu une connexion ssh bizarre et a creusé »
  - Aucune alerte, aucun système de détection n'avait été déclenché, juste quelqu'un qui a trouvé cela bizarre.
  - Evidement une fois sur l'ESXI ils ont constaté les dégâts.
  - Et le RSSI a joué le jeu à fond !
- ⇒ Analyses h24 + appel à une boîte pour le forensic externe + déclaration à la CNIL
- ⇒ En moins de 3j ils avaient changés tous les mots de passe de la NTDS !





## Conclusion

### Synthèse et perspectives

**Quatre ans de Red Team, c'est une évolution constante, des défis relevés, et une adaptation continue**

**Merci pour votre attention et rendez-vous pour les prochaines missions !**





**Questions ?**